

GKUC SiteOps Application Audit Findings

Read-only audit report for /Users/thinuladamsith/Desktop/gkuc-construction. Date: 22 Aug 2026. Scope: backend, frontend, tests, package configuration, permission guards, uploads/storage, generated documents and production-readiness signals. Missing external API integrations were excluded from findings.

Executive Summary

Severity	Count
High	4
Medium	4
Low	4

Verification Signals

Check	Result
npm run build	Passed - frontend production build completed
npm test	Failed - 19 backend tests passed, 2 backend tests failed
pnpm audit --prod	Failed - 5 production vulnerabilities reported
Static security search	Completed - auth, permissions, uploads, storage, document rendering and frontend injection patterns reviewed

Detailed Findings

High

1. High - Security - Dependencies: Production dependency audit reports exploitable transitive vulnerabilities

Evidence

- npm audit --prod reports 5 production vulnerabilities: 1 high, 2 moderate and 2 low.
- Affected transitive packages include path-to-regexp, qs and body-parser through Express.
- Evidence paths: backend/package.json:14, pnpm-lock.yaml:852, pnpm-lock.yaml:866, pnpm-lock.yaml:481.

Impact

The backend depends on packages with denial-of-service related advisories in the production dependency tree.

High

2. High - Security - Authorization: Performance reviews are readable by any authenticated account

Evidence

- backend/src/routes/payroll.js:111 defines router.get('/reviews/all', auth, wrap(...)) without a permission guard.
- The returned data includes employee names, review scores, strengths and improvement notes from performance_reviews.

Impact

Sensitive HR performance data is exposed beyond HR/payroll users to every signed-in user.

High

3. High - Security - Authorization: Admin permission catalogue does not match protected routes

Evidence

- backend/src/lib/permissions.js:70 defines admin.audit and backend/src/lib/permissions.js:71 defines admin.notifications.
- backend/src/routes/admin.js:183 protects the audit trail with admin.users instead of admin.audit.
- backend/src/routes/admin.js:234 protects the manual notification scan with admin.users instead of admin.notifications.

Impact

Users granted user-management authority also inherit audit and deadline-scan powers, while purpose-built permissions are not honored.

High

4. High - Security - Gallery Evidence: Withdrawn gallery photos can still be fetched by direct file endpoint

Evidence

- backend/src/routes/gallery.js:119 hides removed photos from normal gallery lists unless the user has gallery.manage.
- backend/src/routes/gallery.js:229 serves /gallery/photos/:id/file with only projects.view and does not check removed_at.
- backend/src/routes/gallery.js:230 selects storage_key, thumb_key, mime and filename only, so removed state is unavailable to the route.

Impact

A user with project viewing access and a known withdrawn photo ID can still retrieve image bytes that the gallery list intentionally hides.

Medium

5. Medium - Reliability - Uploads: Generic upload routes accept gallery as a folder but do not support it as an attachment owner

Evidence

- backend/src/lib/storage.js:32 includes gallery in FOLDERS.
- backend/src/routes/uploads.js:24-31 READERS omits gallery; backend/src/routes/uploads.js:10-17 WRITERS omits gallery.
- backend/src/routes/uploads.js:34-37 OWNER_TABLES omits gallery.
- backend/src/schema.js:444 attachment owner_type enum omits gallery.
- backend/src/routes/uploads.js:104 calls READERS[ownerType].some(...), which throws when ownerType is gallery.

Impact

Requests under /api/uploads/gallery/:id can hit a server error path because storage folder names and attachment owner types are mixed.

Medium

6. Medium - Production Readiness - Tests: Full application test suite is failing

Evidence

- npm test result: 21 backend tests executed, 19 passed and 2 failed. Frontend tests did not run because backend failure stopped the root script.
- backend/test/api.test.js:124 expects goods receipt to create a purchase_order expense, but backend/src/routes/purchasing.js comments state stocked materials are not expensed on receipt to avoid double-charging.
- backend/test/api.test.js:274 expects public /uploads/... file serving, while backend/src/index.js:135 documents authenticated /api/uploads/file/:id serving.

Impact

The suite no longer matches current behavior, so CI cannot reliably distinguish regressions from stale assertions.

Medium

7. Medium - Production Readiness - Object Storage: Object storage download path is intentionally incomplete for non-local storage

Evidence

- backend/src/routes/uploads.js:84-88 returns 501 when storage is not local.
- backend/src/routes/gallery.js:235-236 returns 501 when storage is not local.
- backend/src/lib/storage.js includes an R2 driver for writes and deletes, but authenticated signed downloads are not implemented in serving routes.

Impact

A deployment configured with STORAGE_DRIVER=r2 can upload objects but cannot serve them through the protected download endpoints.

Medium

8. Medium - Coding Standards - Guard Coverage: Some authenticated routes rely on auth only despite returning sensitive operational data

Evidence

- backend/src/routes/payroll.js:111 is auth-only for performance reviews.
- backend/src/routes/admin.js:24, 65 and 100 expose company and document settings to all signed-in users. This appears intentional from comments, but the route pattern should be explicitly reviewed because these settings include bank and business identity data.
- backend/src/routes/finance.js:10 exposes finance categories to all signed-in users.

Impact

The codebase has inconsistent route guard expectations, increasing the chance of future sensitive endpoints being added with auth only.

Low

9. Low - Code Quality - Tooling: No lint or formatting command is defined

Evidence

- Root package.json defines setup, seed, dev, build, start and test only.
- backend/package.json defines dev, start, seed and test only.
- frontend/package.json defines dev, build, preview and test only.

Impact

Style, unused code, unreachable code and common JavaScript/React mistakes depend on manual review rather than an automated standard.

Low

10. Low - Code Quality - Test Hygiene: Security-improving behavior is contradicted by stale tests

Evidence

- backend/test/api.test.js:274 describes public upload URL serving as expected behavior.
- backend/src/index.js:130-139 explicitly documents that stored objects are not mounted statically and /uploads returns 404.

Impact

Tests can accidentally pressure future changes back toward older, less secure behavior.

Low

11. Low - Audit Coverage Observation: No obvious raw SQL injection or React HTML injection found in the reviewed paths

Evidence

- Route queries mostly use parameter placeholders for user values.
- Dynamic SQL identified in reviewed routes is generally built from fixed maps, catalogues or known column sets.
- Frontend scan did not find dangerouslySetInnerHTML or direct innerHTML usage.
- backend/src/lib/documents.js:17 defines escaping for generated document HTML.

Impact

The major issues identified in this audit are authorization, dependency, test-readiness and edge-case reliability problems rather than direct injection findings.

Low

12. Low - Audit Coverage Observation: Temporary mock/static client-review API layer was not found in active source

Evidence

- Searches for mockApi, static mode and generate hooks did not identify an active frontend mock API layer.
- frontend/src/api.js uses /api paths for backend communication.
- Generated/document wording occurrences were ordinary product comments or UI copy, not static client-review hooks.

Impact

The current source appears aligned with the real backend API flow, excluding the intentionally pending external client APIs.

Reviewed Surfaces

- Authentication and session flow: backend/src/routes/auth.js and backend/src/lib/http.js.
- Authorization catalogue and route guards: backend/src/lib/permissions.js plus backend/src/routes/*.js.
- Uploads and protected file serving: backend/src/lib/storage.js, backend/src/routes/uploads.js and gallery routes.
- Generated document rendering: backend/src/lib/documents.js and document preview/output endpoints.
- Frontend API, token storage, attachment rendering and gallery rendering paths under frontend/src.
- Automated checks: root test/build scripts, pnpm production dependency audit and source searches.

Excluded From Findings

External client API integrations that are pending client response were excluded, according to the audit instruction.